Icône Ajouter Ajouter une couverture

8. Securite

Audit et documentation de sécurité — VPS privatiq.fr

Architecture générale

	Service	Exposition	Port
1	SSH	Public (port custom)	51478/tcp
2	HTTP	Public	80/tcp
3	HTTPS	Public	443/tcp
4	SMTP	Public	25/tcp
5	SMTP submission	Public	587/tcp
6	IMAPS	Public	993/tcp
7	TURN/STUN	Public	3478/tcp+udp
8	TURNS	Public	5349/tcp+udp
9	Redis	Localhost uniquement	127.0.0.1:7654
10	MariaDB (Mailcow)	Localhost uniquement	127.0.0.1:13306
11	MariaDB (Nextcloud)	Réseau Docker interne	3306
12	Nextcloud	Réseau Docker interne	172.17.0.1:8080
13	Collabora	Réseau Docker interne	172.17.0.1:9980

---

1. Firewall (UFW)

Configuration actuelle

Shell

```
Default : DENY entrant, ALLOW sortant
```

	Port	Protocole	Action	Justification
1	22/tcp	TCP	DENY	Port SSH standard bloqué
2	51478/tcp	TCP	ALLOW	Port SSH custom
3	25/tcp	TCP	ALLOW	Réception emails (SMTP)
4	80/tcp	TCP	ALLOW	Redirection HTTP → HTTPS
5	443/tcp	TCP	ALLOW	HTTPS (Mailcow, Nextcloud, Collabora)
6	587/tcp	TCP	ALLOW	Envoi emails (SMTP submission)
7	993/tcp	TCP	ALLOW	Réception emails (IMAPS)
8	110/tcp	TCP	DENY	POP3 non chiffré — désactivé
9	143/tcp	TCP	DENY	IMAP non chiffré — désactivé
10	995/tcp	TCP	DENY	POP3S — désactivé
11	4190/tcp	TCP	DENY	Sieve — désactivé
12	3478	TCP+UDP	ALLOW	Coturn STUN/TURN (Nextcloud Talk)
13	5349	TCP+UDP	ALLOW	Coturn TURNS (chiffré)

Vérification

Shell

```
sudo ufw status verbose
```

---

2. SSH

Configuration

Shell

```
Port           : 51478 (non standard)
Authentification : Clé publique uniquement
PasswordAuthentication : no
X11Forwarding  : no
MaxAuthTries   : 3
AllowUsers     : leo will
```

Pourquoi ces choix

- **Port non standard** : réduit drastiquement les tentatives automatisées
- **Clé uniquement** : rend les attaques par brute-force inutiles
- **AllowUsers** : restreint SSH aux seuls comptes autorisés même si d'autres comptes système existent

Vérification

```shell
sudo cat /etc/ssh/sshd_config | grep -v "^#" | grep -v "^$"

```

---

3. Fail2ban

Jails actifs

	Jail	Service protégé
1	sshd	Tentatives SSH échouées
2	postfix	Tentatives SMTP abusives
3	dovecot	Tentatives IMAP échouées
4	nginx-http-auth	Tentatives HTTP auth échouées

Configuration

```shell
bantime  : 3600 secondes (1h)
findtime : 600 secondes (10min)
maxretry : 5 tentatives

```

Vérification

```shell
sudo fail2ban-client status
sudo fail2ban-client status sshd
sudo fail2ban-client status postfix
sudo fail2ban-client status dovecot

```

---

4. Comptes utilisateurs

Comptes avec accès shell

	Utilisateur	Sudo	Rôle
1	root	—	Superutilisateur système
2	ubuntu	✅	Compte OVH par défaut
3	leo	✅	Administrateur principal
4	will	✅	Collaborateur

Règles appliquées

- Authentification SSH par clé uniquement pour tous les comptes
- Pas de connexion par mot de passe
- Les comptes système (www-data, etc.) sont en `nologin`

Vérification

Shell

```
cat /etc/passwd | grep -v nologin | grep -v false
getent group sudo

```

---

5. Conteneurs Docker

Principe d'isolation

Aucun service interne (base de données, cache) n'est exposé sur une interface publique :

- **Redis** → `127.0.0.1:7654` uniquement
- **MariaDB Mailcow** → `127.0.0.1:13306` uniquement
- **MariaDB Nextcloud** → réseau Docker interne uniquement
- **Nextcloud** → `172.17.0.1:8080` (bridge Docker, inaccessible depuis internet)
- **Collabora** → `172.17.0.1:9980` (bridge Docker, inaccessible depuis internet)

Vérification

Shell

```
sudo docker ps --format "table {{.Names}}\t{{.Ports}}"

```

---

6. Permissions des fichiers sensibles

	Fichier	Permissions	Propriétaire
1	`/opt/mailcow-dockerized/mailcow.conf`	600	root:root
2	`/opt/nextcloud/docker-compose.yml`	600	root:root
3	`/opt/collabora/docker-compose.yml`	600	root:root
4	`/etc/turnserver.conf`	640	root:turnserver

Vérification

Shell

```
ls -la /opt/mailcow-dockerized/mailcow.conf
ls -la /opt/nextcloud/docker-compose.yml
ls -la /opt/collabora/docker-compose.yml
ls -la /etc/turnserver.conf

```

---

7. Mises à jour système

Mises à jour automatiques

Le service `unattended-upgrades` applique automatiquement les correctifs de sécurité.

Shell

```
sudo systemctl status unattended-upgrades

```

Mises à jour manuelles

Shell

```
sudo apt update && sudo apt upgrade -y

```

Mise à jour du kernel

Après une mise à jour du kernel, un redémarrage est nécessaire :

Shell

```
sudo reboot
# Vérifier après redémarrage
uname -r

```

---

8. Checklist de vérification périodique

À effectuer **une fois par mois** :

Shell

```
# 1. Mises à jour disponibles
sudo apt list --upgradable 2>/dev/null

# 2. Statut des jails fail2ban
sudo fail2ban-client status

# 3. Tentatives de connexion SSH
sudo journalctl -u ssh --since "30 days ago" | grep "Failed\|Invalid" | wc -l

# 4. Tous les conteneurs tournent
sudo docker ps --format "table {{.Names}}\t{{.Status}}"

# 5. Ports en écoute (vérifier qu'aucun port inattendu n'est apparu)
sudo ss -tulnp | grep -v "127.0.0.1\|172.17\|172.22"

# 6. Espace disque
df -h

# 7. Charge CPU/RAM
free -h && uptime

```

---

9. En cas d'incident

Bannir une IP manuellement

Shell

```
sudo fail2ban-client set sshd banip <IP>

```

Voir les IPs bannies

Shell

```
sudo fail2ban-client get sshd banned

```

Débannir une IP

Shell

```
sudo fail2ban-client set sshd unbanip <IP>

```

Vérifier les logs d'accès nginx

Shell

```
sudo docker exec mailcowdockerized-nginx-mailcow-1 tail -100 /var/log/nginx/access.log

```